

XFE OAuth2 操作指南

API 连接 · 后台管理 · 前台用户使用
基于 Magento 1 的 OAuth 2.0 认证系统

版本 1.0.0 | 生成日期 2026-05-18

目录

- 一、模块概述
- 二、后台管理操作指南
 - 2.1 配置社交登录
 - 2.2 管理 OAuth 2.0 客户端
 - 2.3 管理访问令牌
- 三、API 连接指南
 - 3.1 授权码模式 (Authorization Code)
 - 3.2 客户端凭证模式 (Client Credentials)
 - 3.3 刷新令牌 (Refresh Token)
 - 3.4 令牌验证
- 四、REST API 端点参考
 - 4.1 产品 API
 - 4.2 分类 API
 - 4.3 购物车 API
 - 4.4 订单 API
 - 4.5 客户 API
- 五、前台用户使用指南
 - 5.1 社交登录 (Google / 微信)
 - 5.2 管理已连接的社交账号
 - 5.3 OAuth 授权流程 (给第三方应用授权)
- 六、常见问题与排错
- 七、附录：数据库表结构

一、模块概述

XFE OAuth2 是 Magento 1 的 OAuth 2.0 认证模块，基于 bshaffer/oauth2-server-php 库实现。它提供了完整的 OAuth 2.0 授权框架，支持三种 Grant Type（授权码模式、客户端凭证模式、刷新令牌），以及 Google/微信社交登录功能。

核心功能

- OAuth 2.0 认证服务器 - 支持 authorization_code, client_credentials, refresh_token 三种授权模式
- RESTful JSON API v2 - 提供产品、分类、购物车、订单、客户等接口
- 社交登录 - 支持 Google 和微信登录，可自动创建或关联已有客户账号
- 后台管理 - 管理客户端、访问令牌、系统配置

前端路由入口

路由	用途	HTTP 方法
/oauth2/token	获取/刷新访问令牌	POST
/oauth2/token/info	验证令牌信息	GET
/oauth2/authorize	用户授权确认页	GET
/oauth2/authorize/confirm	提交授权决定	POST
/oauth2/login/google	Google 社交登录跳转	GET
/oauth2/login/wechat	微信社交登录跳转	GET
/oauth2/login/callback	社交登录回调	GET
/api/v2/*	REST API 资源	GET/POST

可用 Scope (权限范围)

Scope	说明	适用 API
basic	基础权限 - 查看产品和分类	Products, Categories, Cart
orders	订单权限 - 查看自己的订单	Orders
customers	客户权限 - 查看客户信息	Customers
admin	管理权限 - 查看所有客户数据	Customers (列表)

二、后台管理操作指南

2.1 配置社交登录

进入 **系统 > 配置 > XFE > OAuth2 Login** 进行社交登录配置。

Google 登录配置

- 在 **Google Cloud Console** 创建一个 OAuth 2.0 客户端 (Web application 类型)
- 将系统显示的回调 URL 填入 Google 的 **Authorized redirect URIs** 字段
- 在 Magento 后台填入 Google 提供的 Client ID 和 Client Secret

回调 URL 格式：

```
https://□□□□/oauth2/login/callback?provider=google
```

微信登录配置

- 在 **微信开放平台** 注册网站应用，获取 App ID 和 App Secret
- 将系统显示的回调 URL 填入微信平台的授权回调域
- 在 Magento 后台填入微信的 App ID 和 App Secret

回调 URL 格式：

```
https://□□□□/oauth2/login/callback?provider=wechat
```

2.2 管理 OAuth 2.0 客户端

路径：**XFE > OAuth 2.0 Clients**

创建客户端

点击右上角“添加客户端”按钮，填写以下信息：

字段	说明	示例
Name	客户端名称	My Mobile App
Description	描述（可选）	iOS 商城应用
Redirect URI	授权回调地址（授权码模式必需）	https://myapp.com/oauth/callback
Grant Types	授权类型（逗号分隔）	authorization_code,refresh_token
Allowed Scopes	权限范围（空格分隔）	basic orders customers
Status	启用/禁用	Active

保存后系统会自动生成 **Client ID** (UUID v4 格式) 和 **Client Secret** (64位十六进制字符串)。Client Secret 仅在创建时显示一次，请立即安全保存！

可用的 Grant Types

Grant Type	说明	适用场景
authorization_code	授权码模式，需要用户交互授权	第三方应用访问用户数据
client_credentials	客户端凭证模式，无需用户参与	服务器到服务器通信
refresh_token	刷新令牌，用于延长访问令牌有效期	长期访问

2.3 管理访问令牌

路径：XFE > Access Tokens

在该页面可以：

- 查看所有已颁发的访问令牌
- 查看令牌的 Client ID、User ID、User Type、Scope、过期时间
- 点击 Revoke 按钮撤销（删除）指定令牌

安全建议：如怀疑令牌泄露，应立即撤销相关令牌。系统会自动清理过期令牌。

三、API 连接指南

XFE OAuth2 提供标准的 OAuth 2.0 认证端点。第三方应用需要先获取访问令牌 (Access Token) , 然后在请求 API 时通过 Authorization 请求头传递令牌。

3.1 授权码模式 (Authorization Code)

适用于需要代表用户操作的第三方应用 (如移动端商城) 。需要用户交互授权。

步骤一：构造授权链接

将用户浏览器重定向到以下地址：

```
GET https://[url]/oauth2/authorize ?response_type=code &client_id=[id]ClientID
&redirect_uri=[uri] &scope=basic orders &state=[state]
```

步骤二：用户授权

未登录用户会被要求先登录。登录后看到授权确认页，显示应用名称和请求的权限。用户点击 Approve 后，浏览器被重定向到指定的 redirect_uri，并附带 authorization code。

步骤三：换取访问令牌

POST 请求到令牌端点换取 Access Token：

```
POST https://[url]/oauth2/token Content-Type: application/x-www-form-urlencoded
grant_type=authorization_code &code=[code] &redirect_uri=[uri]
&client_id=[id]ClientID &client_secret=[secret]ClientSecret
```

3.2 客户端凭证模式 (Client Credentials)

适用于服务器到服务器通信，无需用户参与。

```
POST https://[url]/oauth2/token Content-Type: application/x-www-form-urlencoded
grant_type=client_credentials &client_id=[id]ClientID &client_secret=[secret]ClientSecret
&scope=basic
```

注意：客户端凭证模式获取的 token 的 user_type 为 client，没有关联的 customer，只能访问不需要用户上下文的 API (如产品列表) 。

3.3 刷新令牌 (Refresh Token)

Access Token 有效期为 1 小时。使用 Refresh Token 获取新的 Access Token，无需用户重新授权。

```
POST https://[url]/oauth2/token Content-Type: application/x-www-form-urlencoded
grant_type=refresh_token &refresh_token=[refresh_token] &client_id=[id]ClientID
```

```
&client_secret=ClientSecret
```

Refresh Token 有效期为 30 天。每次成功刷新会同时返回新的 Access Token 和新的 Refresh Token。

3.4 令牌验证

验证 Access Token 是否有效：

```
GET https://example.com/oauth2/token/info Authorization: Bearer access_token
```

cURL 示例

```
# curl -X POST https://example.com/oauth2/token \
-d "grant_type=client_credentials" \
-d "client_id=xxx" \
-d "client_secret=yyy" \
-d "scope=basic" # API curl -H "Authorization: Bearer YOUR_TOKEN" \
https://example.com/api/v2/products
```

四、REST API 端点参考

所有 API 请求都需要在 HTTP 头中携带 Bearer Token:

```
Authorization: Bearer access_token
```

4.1 产品 API (Scope: basic)

获取产品列表

```
GET https:///api/v2/products?page=1&limit;=20
```

返回包含 id、sku、name、price、currency、url、image 等字段的分页列表。

获取产品详情

```
GET https:///api/v2/products/{id}
```

返回包含描述、短描述、特价、库存状态等详细信息。

4.2 分类 API (Scope: basic)

```
GET https:///api/v2/categories
```

返回完整的分类树结构, 包含 id、name、parent_id、is_active、level、product_count 等字段。

4.3 购物车 API (Scope: basic, 需要客户级令牌)

获取购物车

```
GET https:///api/v2/cart
```

返回当前客户的购物车信息, 包括商品数量、小计、总计及商品明细。

添加商品到购物车

```
POST https:///api/v2/cart Content-Type: application/x-www-form-urlencoded
product_id=123&qty;=2
```

4.4 订单 API (Scope: orders, 需要客户级令牌)

```
GET https:///api/v2/orders?page=1&limit;=20
```

返回当前客户的所有订单 (仅限自己的订单)。

```
GET https:///api/v2/orders/{increment_id}
```

返回订单的完整信息, 包括状态、金额、商品明细、收货地址和账单地址。

4.5 客户 API (Scope: customers)

获取客户列表 (需要 admin scope)

```
GET https://□□□□/api/v2/customers?page=1&limit;=20
```

此接口需要令牌的 scope 包含 admin, 否则返回 401。

获取客户详情

```
GET https://□□□□/api/v2/customers/{id}
```

普通令牌只能查看自己的客户信息 (id 必须与令牌关联的 user_id 一致), 拥有 admin scope 的令牌可以查看任意客户。

五、前台用户使用指南

5.1 社交登录 (Google / 微信)

前台用户在登录/注册页面可以看到社交登录按钮。如果后台已启用和/或微信登录，页面顶部会显示对应的社交登录按钮。

Google

操作步骤

- 1. 访问商城登录页面 (/customer/account/login) 或注册页面
- 2. 点击 Google 或 微信 按钮
- 3. 系统跳转到对应的第三方平台授权页面
- 4. 在第三方平台确认授权
- 5. 授权成功后自动登录商城

首次使用社交登录时：

- 如果该社交账号的邮箱与商城已有账号匹配，则自动关联到该账号
- 如果邮箱不匹配或未提供邮箱，系统自动创建一个新账号
- 自动生成的密码为随机安全密码，用户可通过“忘记密码”功能重置

5.2 管理已连接的社交账号

登录后，在“我的账户”页面左侧导航中点击 Connected Accounts。

页面列出已连接的所有社交账号（显示提供商名称和用户昵称/邮箱）。

- 点击 Disconnect 按钮即可解除绑定
- 在 Connect a new account 区域点击对应平台的连接按钮连接新账号

5.3 OAuth 授权流程 (给第三方应用授权)

当第三方应用（如某款手机 App）需要访问用户的商城数据时，会引导用户完成 OAuth 授权流程：

- 1. 在第三方应用中点击“授权/绑定账号”按钮
- 2. 浏览器打开商城的授权确认页，显示应用名称和请求的权限
- 3. 如果尚未登录，先使用账号密码或社交登录登录
- 4. 查看应用请求的权限，点击 Approve 授权或 Deny 拒绝
- 5. 授权成功后，第三方应用获取 Access Token，开始调用 API

六、常见问题与排错

错误码参考

HTTP 状态码	错误类型	原因	解决方法
400	invalid_request	请求参数缺失或格式错误	检查请求参数是否完整
400	invalid_client	Client ID 或 Secret 错误	检查客户端凭证
400	invalid_grant	授权码/刷新令牌无效或过期	重新授权
400	invalid_scope	请求的 Scope 不被允许	检查客户端的 Allowed Scopes
401	unauthorized	缺少 Bearer Token 或令牌无效	检查 Authorization 请求头
401	insufficient_scope	令牌权限不足	使用更高权限的令牌
403	forbidden	无权访问该资源	该资源不属于当前用户
404	not_found	资源不存在	检查请求路径和 ID
405	method_not_allowed	不支持的 HTTP 方法	检查请求方法是否正确

常见问题

Q: 获取令牌时返回 invalid_client

检查 `Client ID` 和 `Secret` 是否正确。Client ID 和 Secret 在创建时以明文显示一次，如果遗失则需要创建新的客户端。

Q: 授权码模式回调时返回 invalid_grant

授权码有效期较短，获取后请尽快换取令牌。请检查 `redirect_uri` 是否与客户端配置完全一致。

Q: 社交登录按钮不显示

确认后台系统配置中已启用对应社交登录（Google/微信），并且已正确填写 `App ID` 和 `Secret`。检查前台页面是否有 CSS 文件加载。

Q: API 返回 401 Missing Bearer token

确认请求头中包含 `Authorization: Bearer {token}`。注意 Bearer 和令牌之间有一个空格。

Q: 令牌过期了怎么办

使用 Refresh Token 获取新的 Access Token，无需重新授权。如果 Refresh Token 也过期了（30天后），则需要重新走授权流程。

七、附录：数据库表结构

xfe_oauth2_client - 客户端表

字段	类型	说明
client_id	VARCHAR(80) PK	UUID v4 客户端标识
client_secret	VARCHAR(255)	bcrypt 哈希存储的密钥
name	VARCHAR(255)	客户端名称
redirect_uri	TEXT	授权回调 URI
grant_types	VARCHAR(255)	逗号分隔的授权类型
scopes	VARCHAR(255)	空格分隔的权限范围
status	SMALLINT	1=激活, 0=禁用
created_at	DATETIME	创建时间
updated_at	DATETIME	更新时间

xfe_oauth2_access_token - 访问令牌表

字段	类型	说明
access_token	VARCHAR(80) PK	令牌值
client_id	VARCHAR(80)	关联客户端 ID
user_id	INT	所属用户 (customer_id)
user_type	VARCHAR(20)	customer 或 client
expires	INT	过期 Unix 时间戳
scope	VARCHAR(255)	权限范围
created_at	DATETIME	创建时间

xfe_oauth2_refresh_token - 刷新令牌表

字段	类型	说明
refresh_token	VARCHAR(80) PK	刷新令牌值
client_id	VARCHAR(80)	关联客户端 ID
user_id	INT	所属用户

字段	类型	说明
user_type	VARCHAR(20)	customer 或 client
expires	INT	过期 Unix 时间戳
scope	VARCHAR(255)	权限范围
created_at	DATETIME	创建时间

xfe_oauth2_authorization_code - 授权码表

字段	类型	说明
code	VARCHAR(80) PK	授权码值
client_id	VARCHAR(80)	关联客户端 ID
user_id	INT	授权用户 ID
redirect_uri	TEXT	回调 URI
expires	INT	过期 Unix 时间戳
scope	VARCHAR(255)	权限范围
created_at	DATETIME	创建时间

xfe_oauth2_social_account - 社交账号绑定表

字段	类型	说明
id	INT PK AUTO	自增主键
customer_id	INT	绑定的客户 ID
provider	VARCHAR(50)	google 或 wechat
provider_user_id	VARCHAR(255)	第三方平台用户 ID
email	VARCHAR(255)	邮箱
name	VARCHAR(255)	昵称
avatar_url	TEXT	头像链接
created_at	DATETIME	创建时间